

▪ **Flake8**

While not exclusively focused on security, Flake8 is a popular linter and code formatter that can help improve the quality and security of your Python code. Flake8 can identify potential security issues such as unused imports, insecure string formatting, and undefined variables.

Link: <https://pypi.org/project/flake8/>

Installation: `pip install flake8`

Usage: `flake8 <path/to/your/code>`

▪ **CodeQL**

CodeQL is a powerful static analysis engine developed by GitHub. It can be used to find security vulnerabilities and code smells in various programming languages, including Python.

Link: <https://codeql.github.com>

Installation: `pip install codeql-cli`

Usage:

➔ Initialize the CodeQL CLI:

```
codeql database init <programming
language>
```

➔ Download the appropriate CodeQL database for your language:

```
codeql database download --all
```

➔ Create a CodeQL database for your codebase:

```
codeql database create <database-
name> --language=<language> --source-
root=<path-to-your-code>
```

➔ Run a CodeQL query:

```
codeql query run <query-file>.
ql --database=<database-name>
--output=<output-file>
```

➔ View the results of the query — you can do so in the output file specified in the previous step.

▪ **Contrast OSS**

Contrast OSS works by installing an intelligent agent that equips the application with smart sensors to analyse code in real-time from within the application. This allows the software to discover open source dependencies automatically, and provide critical versioning and usage information. Alerts are triggered when risks and policy violations are detected anywhere across the SDLC. The tool monitors, blocks, and alerts on attacks targeting open source libraries and components in production.

Link: <https://www.contrastsecurity.com/open-source-security-software>

Installation: <https://docs.contrastsecurity.com/en/download-contrast.html>

Usage: <https://docs.contrastsecurity.com/en/use-contrast.html>

▪ **ShiftLeft Scan**

ShiftLeft Scan enables you to protect custom code with static analysis (SAST), secure open source libraries (SCA), and employ hard-coded secrets detection and OSS licence violation checks. ShiftLeft Scan claims to be built with usability and rapid time-to-value in mind, with one-click deploy marketplace integrations for popular DevOps tools and cloud infrastructure vendors.

Link: <https://www.shiftright.io/scan/>

Installation: <https://github.com/ShiftLeftSecurity/sast-scan/releases/tag/v2.1.1>

Usage: <https://github.com/ShiftLeftSecurity/sast->

`scan?tab=readme-ov-file#scanning-projects-locally`

In the end, here's a list of a few other development code tools that can act as useful resources.

- SonarQube (<https://www.sonarsource.com/products/sonarqube/>): Best for maintaining code quality.
- ReSharper (<https://www.jetbrains.com/resharper/>): Best for refactoring code.
- CodeClimate (<https://codeclimate.com/>): Best for GitHub users.
- CAST (<https://www.castsoftware.com/highlight/how-it-works>): Best for performing software assessments at scale.
- Codacy (<https://www.codacy.com/>): Best for CI/CD integrations.
- Synk Code (<https:// snyk.io/product/snyk-code/>): Best for security testing.
- Veracode Static Analysis (<https://www.veracode.com/products/binary-static-analysis-sast>): Best for vulnerability scanning and coverage.
- Synopsys Coverity (<https://www.synopsys.com/software-integrity/security-testing/static-analysis-sast.html>): Best for DevOps teams.
- Fortify Static Code Analyzer (SCA) (<https://www.microfocus.com/en-us/cyberres/application-security/static-code-analyzer>): Best for enterprise security.
- PVS-Studio (<https://pvs-studio.com/en/>): Best for game developers.
- PMD (<https://pmd.github.io/>): Best open source code analyser.
- Infer (<https://fbinfer.com/>): Best for mobile developers. 

References

- <https://www.nist.gov/itl/ssd/software-quality-group/source-code-security-analyzers>
- https://www.reddit.com/r/dotnet/comments/16ybzsf/what_are_the_best_free_and_opensource_static/
- <https://github.com/Rohith-sreedharan/OSFY-Code-Analyzer/>

By: S.V. Rohith

The author specialises in RPA, Python, and Web 3.0, and has over five years of expertise in creating and managing Telegram bots.